ISTQB® Certified Tester

Advanced Level — **Security Tester** (CT-SEC, Syllabus 2016)

CHAPTER 6

Human Factors in Security Testing

Complete Study Guide

Chapter fact	Value
Syllabus sections covered	6.1 Understanding the Attackers · 6.2 Social Engineering · 6.3 Security Awareness
Learning objectives	7 examinable (AS-6.1.1 – AS-6.3.2) · K2 = 4 · K3 = 2 · K4 = 1
Recommended teaching time	105 minutes — **9 points**, 5.1 points per teaching hour
Questions in the exam	**5 of 45 questions · 9 of 80 points.** K2 = 2 · **K3 = 2** · **K4 = 1**. Guaranteed: **AS-6.1.2** (K3), **6.1.4** (K4), **6.3.2** (K3). Two K2 from 6.1.1/6.1.3/6.2.1/6.3.1
Exam format	45 questions · **80 points** · **120 minutes** (150 with the 25% non-native-language allowance) · pass mark 65% = **52 points** · K2 = 1 pt · K3 = 2 pts · K4 = 3 pts
Keywords	attacker · botnet · computer forensics · hacker · reconnaissance · script kiddies
Official sample-exam questions	**#33 – #37** (1 + 2 + 1 + 3 + 2 points)

Built exclusively from the ISTQB® Advanced Level Security Tester syllabus (2016), the official Sample Exam (questions and answers, GA March 2016) and the ISTQB® exam structure tables.

Study this single file to master Chapter 6.

Contents

Section 1 — Syllabus Explanation....4
Chapter framing — the human is both threat and weakest defense....4
AS-6.1.1 (K2) — The Impact of Human Behavior on Security Risks....4
AS-6.1.2 (K3) — Understanding the Attacker Mentality....5
AS-6.1.3 (K2) — Common Motivations and Sources of Attacks....6
AS-6.1.4 (K4) — Understanding Attack Scenarios and Motivations....7
AS-6.2.1 (K2) — Social Engineering....8
AS-6.3.1 (K2) — The Importance of Security Awareness....8
AS-6.3.2 (K3) — Increasing Security Awareness....9
Section 2 — Key Concepts....10
2.1 The storyline of Chapter 6....10
2.2 Understanding the attacker....10
2.3 Social engineering and awareness....12
2.4 Fuzzy points clarified....13
2.5 Chapter 6 keyword glossary....13
Section 3 — Tables and Summaries....14
Section 4 — Demo Questions with Answers....15
Part A — The 5 official Chapter 6 questions....15
Part B — 17 additional syllabus-derived questions....16
Most Important Questions From This Chapter....21
Section 5 — Exam Tricks....22
5.1 Frequently tested topics (evidence-based)....22
5.2 Common distractors observed....22
5.3 Keyword recognition (map words → answers)....22
5.4 Typical traps....23
5.5 How to eliminate wrong answers....23
5.6 Scenario-solving shortcuts....23
5.7 Common candidate mistakes....23
5.8 Mnemonics that carry the whole chapter....23
5.9 Chapter 6 mind map....24
Section 6 — Revision Notes....25
6.1 One-page chapter summary....25
6.2 Key definitions to memorize....25
6.3 High-priority concepts (study first)....25
6.4 Last-minute revision sheet....25
6.5 Memorization checklist....25
6.6 Exam-day quick review....26

In Word, right-click the table of contents and choose "Update Field" → "Update entire table" to refresh the page numbers.

How to use this guide

Section 1 explains all seven learning objectives — read it once. **Section 2** explains every key concept from the ground up — plain words, how it works, a worked example, the exam angle, and what it is easily confused with — and ends with the chapter's **fuzzy points clarified**. If the syllabus wording in Section 1 feels dense, read the matching Section 2 card first. **Section 3** holds the tables to reproduce; **table 3.2 (investigation order)** decides the K4. **Section 4** is the question bank, **Section 5** exam tactics, **Section 6** is the revision sheet for the night before.

What makes Chapter 6 unusual: it is about **people, not technology** — attackers, their reconnaissance and motives, forensics, social engineering and awareness. **Three of its five questions are guaranteed scenario items worth 7 points**, at one of the best rates per hour on the paper.

The rule that decides it: think like an investigator. **Start where the evidence begins** (problems began after virus emails → trace the email), **assume the attacker is still inside** until you know how they got in, and **never assume good intent**. After any serious test finding, **check production first**, then turn the case into **awareness material**.

Suggested schedule: Day 1 — Section 1 §6.1. Day 2 — §6.2–6.3, Sections 2–3. Day 3 — Section 4 and Section 5. Day 4 onwards — redo the questions you missed and re-read Section 2's fuzzy points. Night before — Section 6.

Section 1 — Syllabus Explanation

Chapter 6, **Human Factors in Security Testing**, carries **7 learning objectives** across three sub-chapters (6.1 Understanding the Attackers · 6.2 Social Engineering · 6.3 Security Awareness). The Exam Structure Table allocates **5 questions** and **9 of the 80 points**. Teaching time is **105 minutes** — **5.1 points per teaching hour**, among the best returns on the paper.

Three objectives are guaranteed: **attacker reconnaissance (AS-6.1.2, K3)**, **analyzing an attack scenario (AS-6.1.4, K4)** and **actions to increase awareness after test outcomes (AS-6.3.2, K3) — 7 of the chapter's 9 points**. The remaining two K2 questions are drawn from the four "understand" objectives.

LO ID	K	Objective (syllabus statement)	Qs	Pts
AS-6.1.1	K2	Explain how human behavior can lead to security risks and how it impacts the effectiveness of security testing.	2 of 4†	1 each
AS-6.1.2	**K3**	For a given scenario, demonstrate the ability to identify ways in which an attacker could discover key information about a target and apply measures to protect the environment.	**1**	**2**
AS-6.1.3	K2	Explain the common motivations and sources for performing computer system attacks.	2 of 4†	1 each
AS-6.1.4	**K4**	Analyze an attack scenario (attack performed and discovered) and identify possible sources and motivation for the attack.	**1**	**3**
AS-6.2.1	K2	Explain how security defenses can be compromised by social engineering.	2 of 4†	1 each
AS-6.3.1	K2	Understand the importance of security awareness throughout the organization.	2 of 4†	1 each
AS-6.3.2	**K3**	Given certain test outcomes, apply appropriate actions to increase security awareness.	**1**	**2**
Chapter 6 total	—	**K2 = 2 · K3 = 2 · K4 = 1**	**5**	**9**

*† Two K2 questions drawn from AS-6.1.1, 6.1.3, 6.2.1, 6.3.1 — the Sample Exam drew **6.1.1** (Q33) and **6.1.3** (Q35).*

Exam allocation you must know

Chapter 6 = **5 questions / 9 points**; Sample Exam **#33 to #37** (1 + 2 + 1 + 3 + 2 points).

The one thing that decides this chapter

Think like the investigator: start where the evidence points, and assume the attacker is still in. The 3-point forensic scenario (Q36) is answered by **checking the suspicious email and tracing its IP address** — the problems started after virus-infected emails, so that is where the trail begins. The Shodan scenario (Q34) is answered by **"yes, be concerned — he can still access the system"**: fixing the vulnerability does not remove an attacker who is already inside. Never assume good intent ("white hat"), never assume a patch closes a breach.

Chapter framing — the human is both threat and weakest defense

In the context of information security, the human being is both the largest threat and weakest point in defense. Attacks are performed by people with various skills and motivations, and **humans are the (biggest) enablers for most attacks**. Understanding the technology is not enough: testers need to understand **the mindset, motivations and methods of malicious attackers** and **the human weaknesses in the line of defense**.

AS-6.1.1 (K2) — The Impact of Human Behavior on Security Risks

Original syllabus statement

Explain how human behavior can lead to security risks and how it impacts the effectiveness of security testing.

- **The key phase in any attack is information gathering (reconnaissance). All information published — sometimes unknowingly — about an organization, its systems, etc. will be found and can/will be used. It is not a question of "if" but "when".**
- Besides official publications, **employees publish information about the company on their social networks**; the amount and content **change continuously**, often giving attackers **key information**.
- **Attackers do not use a security policy or predefined procedures.** They decide their strategy **from the information they can collect**, and **update their knowledge base** for each attack with selective searches and **visits to already known IP addresses**.
- Security policies are written **from the facts available at the time** — often **not including all publicly accessible information**, which **is likely to change anyway**.
- **Impact on testing: security tests that were valid when created may not provide adequate coverage when published information changes.**

How the official exam used this objective

Sample Q33: which is a potential security risk? **Publishing an accounting department's organization chart on the company's web site** — it reveals **approval chains for invoices**, which could be used to **create and approve fake invoices** if the accounting system is hacked. Rejected: birthday wishes on Facebook (birth dates **should not be used** in passwords anyway); the phone directory on the **intranet** (behind the firewall); professional experience on LinkedIn (**unlikely to be useful** to a hacker). **The risk is published information that reveals process or authority.**

AS-6.1.2 (K3) — Understanding the Attacker Mentality

Original syllabus statement

For a given scenario, demonstrate the ability to identify ways in which an attacker could discover key information about a target and apply measures to protect the environment.

During **reconnaissance or footprinting**, the attacker gathers all kinds of information **by passive and/or active means**. **Most IT equipment facing public networks leaves a footprint, and these footprints can and will be found.**

Passive vs active reconnaissance

	Passive (without connecting to the target)	Active (touching the system)
Sources / tools	**Google** (incl. **Google Earth and Street View**) and other search engines · **Shodan** · **Facebook, LinkedIn** and other social networks · **The Google Hacking Database** (hundreds of queries) · **Whois** · **RIPE** (European IP networks) database · **DNS searches**	**Pinging** — Fping, Hping · **TCP/UDP scan** — Nmap, Zenmap · **OS detection** — Nmap, Xprobe2 · **Service fingerprinting** — Nmap compares a discovered service's **fingerprint** with its database to find **type and version**
Information found	**IP addresses, web pages, telephone numbers, names and email address structures, OS and applications**	**Hosts, open ports, OS, applications and versions**
Shodan example	Find **which companies in an area run an Apache server with a vulnerable version**	—

Hiding the evidence

Because hacking is **illegal in most, if not all, countries**, the attacker **tries to destroy all evidence** — also to **lengthen the stay**, **continue using the system in future**, and **use the compromised system or botnet to attack others**. Tools and methods: **NetCat**, **IP Tracer**-style sites, **tunneling**, **altering log files**, **hide tools, rootkits and file streaming**. Most are available on the Internet — e.g. **Kali Linux** and the **OWASP** site.

Protective measures (K3 "apply measures")

The syllabus gives the attack side; the protective side follows from it and from other chapters:

Minimise and review published information — org charts, email address formats, technology details in job adverts, banners exposing versions (reconnaissance is "when", not "if"). **Patch and harden** what Shodan or Nmap fingerprinting would reveal (Chapter 5). **Remote, protected logging** so evidence survives (§5.1.1). **IDS** tuned to detect scanning (Chapter 3's DDoS level 2). **Awareness training** on what employees post (§6.3).

How the official exam used this objective (K3, 2 points)

Sample Q34: someone emails that they **hacked into your financial system using Shodan** and found an **out-of-date, vulnerable OS** on a server. You confirm it and **update the server**, but **find no trace of how they got in**. Should you be concerned? **Yes — since the hacker didn't admit how he got in, he can still access it and may exploit the vulnerability next time.** Rejected: "white hat, means no harm" (**a dangerous assumption**); "fixed, so safe" (**the hacker still has access**); "re-run your tests" (**re-running the same tests won't help**).

AS-6.1.3 (K2) — Common Motivations and Sources of Attacks

Original syllabus statement

Explain the common motivations and sources for performing computer system attacks.

Source	Share	Motivations (syllabus)
Insiders (internal hackers, insider threats) — **malicious authorized users**	**Many attacks** come from inside	**Mostly revenge**; recent trends show **increasing economic espionage or theft**
External hackers	**The minority** of attacks	**Curiosity** (one of the first motivators, still is) · **prestige** (knowing what others don't) · **notoriety or fame · challenge · boredom · revenge — the most dangerous form (highest motivation)**

The attacker spectrum

End	Who	Abilities
Lower end	**Script kiddies — simply execute the attacks others create**	Some system and networking knowledge, a **simple home computer**
Upper end	**Professional (governmental, hacktivism) organizations and individuals**	**Highly trained**, with **labs, proxy networks** and all needed equipment

- **Hacktivism** = attacking systems on **mainly political**, but also **economic or other demographic** grounds.
- Motivation scales **from playing around for fun to knocking an organization completely down** — political, ideological, economic, warfare, commercial, terrorism.
- **Having a picture of potential attackers helps an organization implement protection and gives a guideline for the security test strategy.**

How the official exam used this objective

Sample Q35: why is an inside attack particularly worrisome? **The attacker is already inside the firewall and is an authorized system user — external protections are useless**. Rejected: curiosity and boredom (**more likely with external attackers**); DoS (insiders are **generally after information they can sell or use to embarrass the company**).

AS-6.1.4 (K4) — Understanding Attack Scenarios and Motivations

Original syllabus statement

Analyze an attack scenario (attack performed and discovered) and identify possible sources and motivation for the attack.

A security incident is a security-relevant system event in which the system's security policy is disobeyed or otherwise breached [RFC 2828]. Finding **what happened and who was responsible** is the target of **computer forensics** — finding **digital evidence**. The evidence recovery process has **three phases: acquire and authenticate · analyze · report**.

Phase 1 — Acquire and authenticate

The incident management process should **restore the system to its pre-attack state after evidence is collected and stored**. It starts when the sysadmin is alerted by the **IDS or other monitoring**. **Typical symptoms of security incidents:**

Symptom	Symptom
Suspicious log entries	**Unexplained user accounts**
Modified files/folders	**Unusual services running**
Unusual system behavior	**Unsuccessful login attempts**

The five-step response after an alert

Step	Action
1	**Snapshot or copy** the system under investigation to collect all evidence
2	After **authenticating the evidence** (genuine and complete copy), **create a copy and store it safely**
3	**Analyze** the evidence
4	After forensics, **remove the cause** of the incident — **eradication**
5	Bring the system back to normal — **recovery**

Vulnerabilities are removed during these steps with **patches or new software**. The report describes **the process followed and the tools used**.

Phase 2 — Analyze

- Find the source by examining **system log files** and **active network connections**; **copy all logs** and capture **process status**. **During an active attack, gather information about the attacker before locking them out.**
- **Any Internet attack can be traced to the originating IP address** (email or connection) — **only a matter of time, money and effort**. Attackers use **proxies, chains of proxies, Tor**; **more proxies, more time**; **local laws** where proxies sit may obstruct.
- Tools: **Netstat** (connections, ports, services — look for strange IPs or ports), **Tracert / traceroute**, the **IP Tracer** website.
- **Email:** the header may show the **ISP's IP**; for web mail (Gmail, Yahoo, Outlook.com) look for **X-Originating-IP**; then **Whois** to contact the ISP. **Private servers and open relays** make the source very hard to identify.
- **Botnets are difficult to investigate** — the attacker needs no online connection to the bot server or clients; **investigating clients may lead to the server**, but you need **access to the server**; owners **may not know** their machines are part of a botnet.

Phase 3 — Report

Reporting of security vulnerabilities is covered in **Chapter 7**.

How the official exam used this objective (K4, 3 points)

Sample Q36: root access is tightly held by three trusted admins. Odd events: a program **"IKnowYourBirthday"** emails staff correct

birthday greetings "From your favorite server"; the **phone list is overwritten** (file created by **root**); the **root password is changed** to the **lead admin's dog's name**. The problems **started shortly after a series of virus-infected emails**. Next step? **Check the suspicious email that was sent and try to trace the IP address.**

Rationale: **it appears this might have been where the problem originated**. If that finds nothing, **A** (was HR birthdate data accessed from outside? trace the IP) and **D** (are the other two admins unhappy? — **an internal attack**) are the next paths; **B** (dog's name on social media) could be pursued, **but it is easier just to ask the admin**. **Method: follow the timeline to the first event and start the trace there.**

AS-6.2.1 (K2) — Social Engineering

Original syllabus statement

Explain how security defenses can be compromised by social engineering.

Employees **need access** to assets to do their work, from desktops, notebooks, phones and tablets. **Physical defenses at the office are meaningless if the IT manager's working area at home can easily be compromised. The human being and his or her behavior is the greatest threat** — sloppiness with sensitive information leaves footprints and **broadcasts information too loudly** in public places.

Social engineering is the art of exploiting the human using its general behavior as an attack vector. People are **willing to trust and help strangers**; by **manipulating, influencing and persuading helpful people**, attackers gather **access, authorization details or other sensitive information**.

Direct human interaction (in person)	Computer-based
Tailgating / piggybacking — someone without authentication **follows an employee into a restricted area**	**Emails infected with malware**
Eavesdropping — listening to private conversations without knowledge	**Chat / instant messaging** — anonymous, true identity unknown, **data easily sniffed**
Shoulder surfing — looking over someone's shoulder at the screen or writing	**Pop-up screens** — e.g. "network connection lost, re-enter user name and password"; a planted program sends them to a remote site
Telephone — getting a password by **impersonating a manager or tech support**	**Spam email** — fraudulent offers and links that **install malware**
	Phishing to infected sites — **broad**, or **highly individualized (spear phishing)**

The defense

There is no single defense against social engineering. Damage control: **least privilege**, **separation of duties**, **rotation of duties** — **but the main defense is education and awareness at all levels of the organization.**

AS-6.3.1 (K2) — The Importance of Security Awareness

Original syllabus statement

Understand the importance of security awareness throughout the organization.

- **The threat model is constantly changing**: networks evolve, new applications and interfaces go live, **new vulnerabilities are introduced and discovered**.
- The human factor: **risks once identified but which did not become issues are easily forgotten, and safeguards are withdrawn** — more opportunity for **hacking and social engineering**.

- **Regular security awareness training** keeps **security administrators and all employees alert and informed** about changes in the threat model.
- Training can target **different user groups: developers, operations, management and general staff**.

AS-6.3.2 (K3) — Increasing Security Awareness

Original syllabus statement

Given certain test outcomes, apply appropriate actions to increase security awareness.

Keep a **"security aware" mindset**. Beyond general information about company defenses, training should contain **real case studies — discovered during security testing or in actual incidents**. Building on them makes it **easier to discuss defenses or changes**. The case-study section should answer **six questions**:

#	Question for the awareness case study
1	**How did they (we) do it?**
2	**What were the business consequences?**
3	**What were the costs to investigate and process the incident?**
4	**What were the costs to repair the problem?**
5	**How could the incident have been avoided?**
6	**Which changes will be implemented?**

How the official exam used this objective (K3, 2 points)

Sample Q37: testing an upgrade, a tester performs a **man-in-the-middle attack that changes amounts charged** (a 10% discount). What first? **Check production to see if the vulnerability is also in the production code — get the problem fixed immediately**. Next: **work with developers** on checks such as **SSL-trip** for certificate validity (C). Rejected: discouraging the tester (**this is exactly what security testers should be doing**); telling management afterwards (**permission should always be obtained prior to testing, not afterward**). The case then becomes awareness material: how was it done, consequences, costs, avoidance, changes.

Section 2 — Key Concepts

Section 1 gives the syllabus wording objective by objective. This section explains what that wording means. Each card builds one idea in order: plain words first, then how it works, an example, how the exam uses it, and what it is easily confused with.

2.1 The storyline of Chapter 6

Chapter 6 is about **people on both sides**. On the attacking side: **how attackers find information** about you (reconnaissance), **who they are and why they attack** (motivation), and **how to investigate** an attack once it has happened (forensics). On the defending side: **how your own staff can be manipulated** (social engineering) and **how awareness training keeps them alert**. The thread is the syllabus's opening sentence: **the human being is both the largest threat and the weakest point in defense.**

Two habits decide the scenario questions: **investigate from the first event on the timeline**, and **never assume the attacker is gone, or means well, until you know how they got in**.

2.2 Understanding the attacker

How human behaviour creates security risk (AS-6.1.1)	
In plain words	The **key phase of any attack is information gathering**. Anything published about an organization, whether **deliberately or by accident**, **will be found** by attackers: **"not if, but when"**. Employees add to this every day on **social networks**.
How it works	**Attackers follow no policy or procedure.** They choose their plan **from the information they can collect**, and they keep their knowledge up to date (selective searches, revisiting known IP addresses). **Security policies are written from the facts known at the time**, which rarely include **everything that is publicly available**, and that information keeps changing. **Effect on testing: tests that were adequate when written may lose coverage as published information changes.**
Example	A company publishes its accounting department's organization chart, with names and who approves which invoices. If an attacker later gets into the accounting system, they know **exactly whose approval to forge** for fake invoices. The chart itself is the risk.
Exam angle	Official Q33: the potential risk → **the accounting org chart on the public website** (it reveals the **approval chain**). Birthday wishes on Facebook, an **intranet** phone list and LinkedIn job history are much less useful to an attacker. **Look for published information that reveals process or authority.**
Don't confuse	Information on the **intranet** sits behind the firewall and is a smaller exposure than the same information on the **public** website.

Reconnaissance: passive and active (AS-6.1.2, guaranteed K3)	
In plain words	**Reconnaissance** (or **footprinting**) is collecting information about a target. **Passive** reconnaissance gathers it **without touching the target's systems** (searching public sources). **Active** reconnaissance **sends traffic to the target** to see what answers.
How it works	**Passive sources: Google** (including **Earth and Street View**) and other search engines · **Shodan** (a search engine for **Internet-connected devices**, e.g. "all servers in this area running a vulnerable Apache version") · **Facebook, LinkedIn** and other social networks · the **Google Hacking Database** · **Whois** · the **RIPE** database (European IP networks) · **DNS** searches. They reveal **IP addresses, web pages, phone numbers, names and email formats, OS and applications**. **Active tools: ping** (Fping, Hping) · **TCP/UDP port scans** (Nmap, Zenmap) · **OS detection** (Nmap, Xprobe2) · **service fingerprinting** (Nmap compares a service's response with its database to find the **type and version**). They reveal **hosts, open ports, OS, applications and versions**. **Covering tracks:** because hacking is illegal, attackers **destroy evidence**, both to avoid prosecution and to **stay longer** and **reuse** the system (or a botnet) later. Tools and methods: **NetCat**, **tunneling**, **altering log files**, hiding tools, **rootkits**, file streaming. Most are freely available (e.g. **Kali Linux**, **OWASP**).

Reconnaissance: passive and active (AS-6.1.2, guaranteed K3)	
How to defend	The "apply measures" half of the objective: minimise and review what is published (org charts, email formats, version banners, technology in job adverts) · **patch and harden** what Shodan or fingerprinting would reveal · **remote, protected logging** so evidence survives · an **IDS** that detects scanning · **awareness training** about what staff post.
Example	An attacker searches Shodan for the company's IP range (passive) and sees an old OS version in a server banner. A quick Nmap scan (active) confirms the open ports and service versions. The defender's measures: remove the version banner, patch the OS, and alert on port scans.
Exam angle	Official Q34: someone claims they got in using Shodan and an outdated OS. You patch the server but find **no trace of how they got in**. Should you worry? → **Yes. They did not say how they got in, so they may still have access.** Assuming a "white hat" with good intentions is dangerous, patching does not remove an attacker already inside, and re-running the same tests will not help.
Don't confuse	**Shodan is passive** (it searches data someone else already collected). **Nmap is active** (it sends packets to the target). Whois, RIPE and DNS look-ups are passive.

Who attacks, and why (AS-6.1.3)	
In plain words	Attackers range from **bored teenagers running other people's scripts** to **well-funded professional and state organizations**. Knowing the likely attacker tells you **what to protect and what to test first**.
How it works	**Insiders** (internal hackers, malicious **authorized** users): **many** attacks. Motive: **mostly revenge**, with **economic espionage and theft** increasing. **External hackers**: the **minority** of attacks. Motives: **curiosity** (the original motive), **prestige**, **notoriety or fame**, **challenge**, **boredom**, and **revenge**, **the most dangerous because it gives the strongest motivation**. **The spectrum:** at the **lower end**, **script kiddies** who **simply run attacks others wrote**, on a home computer. At the **upper end**, **professional (governmental, hacktivist) organizations** with training, labs and proxy networks. **Hacktivism**: attacks on **mainly political**, but also economic or other demographic, grounds. A picture of likely attackers **guides protection and the security test strategy**.
Example	A pharmaceutical company's likely attackers are **professional espionage groups** (after research data) and **insiders** (who can download formulas). Testing priorities are therefore authorization and data-loss controls, plus detection and forensics readiness, rather than defenses against website defacement.
Exam angle	Official Q35: why is an insider attack especially worrying? → **the attacker is already inside the firewall and is an authorized user, so external protections are useless.** Curiosity and boredom are **external** motives. Insiders usually want **information they can sell or use to embarrass the company**, not a DoS.
Don't confuse	**Revenge** appears on **both** lists: it is the **main insider motive** and the **most dangerous external motive**. "Most attacks are external" is wrong: the syllabus says **many** come from insiders and external hackers are the **minority**.

Investigating an attack: computer forensics (AS-6.1.4, guaranteed K4)	
In plain words	A **security incident** is an event in which the **security policy is disobeyed or breached** (RFC 2828). **Computer forensics** finds the **digital evidence** of **what happened and who did it**. It has three phases: **acquire and authenticate → analyze → report**.

Investigating an attack: computer forensics (AS-6.1.4, guaranteed K4)	
How it works	**Signs of an incident:** suspicious log entries · unexplained user accounts · modified files or folders · unusual services running · unusual system behaviour · failed login attempts. The process usually starts with an **IDS alert**. **Five steps after an alert:** (1) **snapshot or copy** the system to collect all evidence · (2) **authenticate** the evidence (genuine and complete), **make a copy and store it safely** · (3) **analyze** · (4) **eradicate** the cause · (5) **recover** the system to normal. The aim is to restore the pre-attack state **after** the evidence is safe. **Analysis:** read **system logs** and **active network connections** (copy the logs, capture process status). **During an active attack, gather information about the attacker before locking them out.** Tools: **Netstat**, **Tracert/traceroute**, **IP Tracer** sites. **Any Internet attack can be traced to its originating IP; it is only a matter of time, money and effort.** Proxies, proxy chains and **Tor** add time, and local laws can block access. For email, read the header (the ISP's IP, or **X-Originating-IP** for web mail), then use **Whois** to contact the ISP. **Open relays and private servers** make this very hard. **Botnets** are hard to investigate, and their owners may not know they are part of one. **Report** (detailed in Chapter 7): describe **the process followed and the tools used**.
Example	Official Q36: three trusted admins hold root. Strange things happen: a program e-mails staff correct birthday greetings, the phone list is overwritten by **root**, and the root password is changed to the **lead admin's dog's name**. **It all started shortly after a wave of virus-infected emails.** Next step → **check that suspicious email and trace its IP address.** That is the **first event on the timeline**.
Exam angle	**Method: follow the timeline back to the first event and start there.** Then consider external origins (an IP trace), then internal ones (unhappy admins). If something can be learned cheaply (just **ask** the admin whether the dog's name is public), do that rather than a big investigation.
Don't confuse	**Eradication** (remove the cause) comes **before recovery** (back to normal). And evidence is copied and authenticated **before** anything is cleaned up, or it is lost.

2.3 Social engineering and awareness

Social engineering (AS-6.2.1)	
In plain words	**Social engineering is the art of exploiting people, using their normal behaviour as an attack vector.** People **want to trust and help**. An attacker who **manipulates, influences or persuades** a helpful person can get access, passwords or sensitive information without any technical attack.
How it works	**In person: tailgating / piggybacking** (following an employee through a secured door) · **eavesdropping** · **shoulder surfing** (reading a screen or notes over someone's shoulder) · **telephone** (pretending to be a **manager or tech support** to get a password). **Computer-based: malware-infected emails** · **chat / instant messaging** (identities unknown, and data easily sniffed) · **fake pop-ups** ("connection lost, re-enter your password") · **spam** with fraudulent offers or links · **phishing**, either broad or **highly individualized (spear phishing)**. Physical defenses at the office are **meaningless if the IT manager's home working area is easy to compromise**.
How to defend	**There is no single defense.** Damage is limited by **least privilege**, **separation of duties** and **rotation of duties**, but **the main defense is education and awareness at all levels of the organization**.
Example	A caller says they are from the IT helpdesk, sounds stressed, names the employee's manager (taken from LinkedIn), and asks them to "confirm" their password for an urgent migration. Nothing technical was attacked, but the password is gone.
Exam angle	Recognise each technique from its description, and remember that the syllabus's **main** defense is **education and awareness**, not a technical control.
Don't confuse	**Phishing** is broad. **Spear phishing** is aimed at **one person or group**, with personal details. **Tailgating** is physical. **Shoulder surfing** is visual.

Why security awareness matters, and how test results build it (AS-6.3.1 / 6.3.2, guaranteed K3)	
In plain words	The **threat model never stops changing** (new systems, new interfaces, new vulnerabilities). People forget: **a risk that never turned into an incident is easily forgotten, and its safeguards get withdrawn**. **Regular awareness training** keeps administrators and all staff alert, and it works best when it uses **real cases**, including what **your own security tests** found.
How it works	Train **different groups** differently: **developers, operations, management and general staff**. Include **real case studies**, from security testing or actual incidents. They make it **easier to discuss defenses and changes**. **Six questions for each case study:** (1) **How did they (we) do it?** (2) What were the **business consequences**? (3) What did it **cost to investigate and process**? (4) What did it **cost to repair**? (5) **How could it have been avoided?** (6) **Which changes will be implemented?**
Example	Official Q37: testing an upgrade, a tester performs a **man-in-the-middle attack that changes the amounts charged**. **First: check whether the vulnerability is also in production** and get it fixed **immediately**. **Next:** work with developers on checks such as certificate validation (SSL-trip). **Then:** the incident becomes an awareness case study, answered with the six questions.
Exam angle	In Q37, reject discouraging the tester (**this is exactly what security testers should do**) and "tell management afterwards" (**permission is obtained before testing, never after**). For any test outcome, the first action is the **production check**, the same instinct as Chapter 3's Q16.
Don't confuse	Awareness is **continuous**, not a one-off course. A K3 answer that uses the finding as a **case study with the six questions** beats a generic "send everyone a policy reminder".

2.4 Fuzzy points clarified

Places where the wording is easy to misread

Protective measures for AS-6.1.2 are not spelled out in §6.1.2. The syllabus describes the attacker's methods. The measures in Section 1 and in section 2.2 (minimise published information, patch, remote logs, IDS, awareness) follow from Chapters 3, 5 and 6, and are labelled as this guide's additions.

"Acquire and authenticate" vs the five steps. The three **phases** (acquire and authenticate · analyze · report) and the five **steps** (snapshot · authenticate and copy · analyze · eradicate · recover) are two different lists. Exam options can mix them.

"Any attack can be traced" is not "every attacker will be found". The syllabus adds that it costs time, money and effort, and that proxies, Tor, botnets and local laws can make it impractical.

Q36's rationale also accepts other paths later. The HR birthdate data and the other admins are valid **next** lines of enquiry, but the email trail is **first** because the problems started after the virus emails.

Insider share. The syllabus says **many** attacks come from insiders and external hackers are **the minority**. It gives no percentages, so do not choose an option on the basis of a figure.

2.5 Chapter 6 keyword glossary

Keyword	Working definition for the exam
attacker	A person who attempts to breach security — insider or external, from script kiddie to state actor.
botnet	A large number of previously compromised computers under an attacker's control; hard to trace.
computer forensics	Finding digital evidence of what happened in a security incident and who was responsible.
hacker	Used in the syllabus for attackers; internal hackers are insider threats; ethical hacking is authorized testing (Ch1).
reconnaissance	The information-gathering (footprinting) phase — passive or active — and the key phase of any attack.
script kiddies	Attackers at the lower end who simply execute attacks others create.

Section 3 — Tables and Summaries

3.1 Attacker profile → test strategy implication

Profile	Typical motive	Implication for testing
Insider	Revenge; espionage/theft	Test authorization, segregation of duties, logging; external defenses don't help
Script kiddie	Curiosity, fame, boredom	Known exploits — patching and hardening tests
Hacktivist	Political, economic	Availability (DoS), defacement, data leaks
Professional / governmental	Espionage, warfare	Advanced, persistent; detection and forensics readiness

3.2 Investigation order (Q36 method)

Step	Question
1	What was the **first** anomalous event on the timeline? Start the trace **there**
2	What **external** origin could it have (email IP, connection IP)?
3	Could it be **internal** (who has access, who is unhappy)?
4	What could be learned **cheaply** (just ask the admin) before investigating publicly?

3.3 Social engineering — channel and countermeasure

Technique	Channel	Countermeasure in the syllabus spirit
Tailgating	In person	Physical access control, awareness
Shoulder surfing	In person	Awareness, screen placement
Phone impersonation	Telephone	Verification procedure (identity check before reset — Ch3)
Pop-up re-login	Computer	Malware protection, awareness
Spear phishing	Email	Awareness with real case studies; anti-malware

Reproduce from memory before moving on

Passive vs active reconnaissance tools — the K3 on AS-6.1.2.
Five forensic steps and **six symptoms** — the K4 on AS-6.1.4.
Six case-study questions — the K3 on AS-6.3.2.
Insider vs external motives — a likely K2.

Section 4 — Demo Questions with Answers

*Questions 1–5 are the **official ISTQB CTAL-SEC Sample Exam questions for Chapter 6** — #33 to #37 — with official answers and rationale. LO tags are inferred and match the Exam Structure Table. Questions 6–22 are derived strictly from the syllabus. Correct options are marked ✔.*

Part A — The 5 official Chapter 6 questions

Q1. OFFICIAL · Sample Exam #33 (1 pt)

Which of the following is a potential security risk?

a) Publishing an accounting department's organization chart on the company's web site ✔

b) Posting birthday wishes for a co-worker on Facebook

c) Posting the company phone directory on the company Intranet

d) Posting professional experience in a LinkedIn profile

Correct answer: a | LO: AS-6.1.1 (K2) | Syllabus §6.1.1

Why: (a) — official rationale: **this information could be used to determine approval chains for invoice approvals which could then be used to create and approve fake invoices if the accounting system can be hacked.** (b) **the birth date should not be used in any employee information such as a password**. (c) **the company intranet should be behind the firewall**. (d) **this information is unlikely to be useful to a hacker**. Syllabus §6.1.1: **all information that is published ... will be found and can/will be used in an attack**.

Q2. OFFICIAL · Sample Exam #34 (2 pts)

You are responsible for security testing your company's financial application. You have recently received email from a person who claims to have hacked into the system using Shodan and has discovered that you are running an out-of-date and vulnerable OS on one of your servers. You have checked and the hacker is correct. You have made sure the server has been updated. Your preliminary check has shown no trace of how the hacker got into your system. Should you be concerned?

a) No, this is a "white hat" hacker and means no harm to your company

b) No, you have fixed the vulnerability so the system is now safe

c) Yes, your security testing is not sufficient and you need to re-run your tests to see what was missed

d) Yes, since the hacker didn't admit how he got in the system, he can still access it and may decide to exploit the vulnerability next time ✔

Correct answer: d | LO: AS-6.1.2 (K3) | Syllabus §6.1.2

Why: (d) — official rationale: **that is your biggest point of concern.** (a) **could be a dangerous assumption**. (b) **the hacker still has access to the system**. (c) **may be true, but re-running the same tests is not going to help with this issue**. Syllabus §6.1.2: Shodan finds e.g. **companies running a vulnerable version**; attackers **destroy evidence** to **lengthen the stay** and **continue the use of the system in the future**.

Q3. OFFICIAL · Sample Exam #35 (1 pt)

Why is an attack from inside the organization particularly worrisome?

a) The attacker is likely driven by curiosity and will be unrelenting

b) The attacker is likely bored at work and will continue hacking the system for entertainment

c) The attacker is already inside the firewall and is an authorized system user ✔

d) The attacker is likely to launch a DOS attack which will cripple the servers

Correct answer: c | LO: AS-6.1.3 (K2) | Syllabus §6.1.3

Why: (c) — official rationale: **the biggest threat here is that the external protections are useless because the attacker is already inside the system.** (a) and (b) **are more likely to occur with an external attacker**. (d) **is not the most likely attack – generally internal users are after information they can sell or can use to embarrass the company**. Syllabus §6.1.3: insiders **compromise systems while being an authorized network user**.

Q4. OFFICIAL · Sample Exam #36 (3 pts)

You are working in an organization where system administration access to the servers is highly restricted. Only three long-term and trusted employees know the root passwords. Recently though, there have been several odd occurrences. An unknown program, called "IKnowYourBirthday" was found to be running and was emailing birthday greetings to staff members. The birth dates were correct and the greetings were all signed "From your favorite server". This program was killed and no one could figure out where it came from. A second problem occurred when the corporate phone list was hacked and all the phone numbers were changed to 867-5309 (apparently taken from the song by the same name). The correct list was restored and again no one could figure out how it had been done, although the new file had been created by "root". You've just received a phone call from the lead system administrator telling you that the root password has been changed. It has been determined that the password was set to the lead system administrator's dog's name.

Further investigation has discovered that the problems started shortly after a series of virus–infected emails were detected. When the first one was found, safeguards were immediately put in place to stop any further spread of the virus, but now you are wondering if someone managed to get into the system via code that was introduced into the system by the virus.

What should you do now as your next step of investigation?

a) Look to see if the HR birthdate information was accessed from outside the system, and if so, trace the IP address

b) Verify if the lead system administrator's dog's name is posted somewhere in social media

c) Check the suspicious email that was sent and try to trace the IP address ✔

d) Check the personnel files of the other two system administrators to see if there is an indication that they are unhappy

Correct answer: c | LO: AS-6.1.4 (K4) | Syllabus §6.1.4

Why: (c) — official rationale: **it's the best place to start because it appears that this might have been where the problem originated. If C doesn't find anything, then A and D would be the next likely paths to pursue since it's possible this is an internal attack (D) or that the attacks are separate and the birthdate information might provide some information as to who has been near it. B might be pursued, but it would be easier to just ask the sys admin who would know the dog's name.** Syllabus §6.1.4.2: **in the header of an email containing viruses, the IP address ... may be shown**; use **X-Originating-IP** and **Whois**.

Q5. OFFICIAL · Sample Exam #37 (2 pts)

During testing of an upgrade, you have discovered that it is possible to create a man-in-the-middle attack that can change the amount charged to customers on your e-commerce web site. Your tester successfully changed the amount so that customers were all getting a 10% discount. What should you do first?

a) The tester should be discouraged from creating these types of attacks as they are not realistic in the production environment

b) Immediately inform management that the attack was created by the test team as part of testing, in case it is detected

c) Work with the developers to implement checks such as SSL-trip to ensure certificates are valid and not self-signed

d) Check production to see if the vulnerability is also in the production code ✔

Correct answer: d | LO: AS-6.3.2 (K3) | Syllabus §6.3.2, §3.5

Why: (d) — official rationale: **the first priority is to see if the vulnerability is in the production code and get the problem fixed immediately. C should be the next step to ensure the developers are coding correctly and using all available tools to check for this type of issue. A is incorrect because this is exactly what security testers should be doing. B is incorrect because management permission should always be obtained prior to testing, not afterward.**

Part B — 17 additional syllabus-derived questions

*The K-level in each question's label is the level of the **learning objective** it practises, not of the question itself. Some Part B items are quick recall checks on a K3 or K4 objective. Use them to learn the facts, and use the scenario items (and Part A) to practise the reasoning the real K3/K4 questions need.*

Q6. Derived from syllabus

According to the syllabus, what is the key phase in any attack?

a) Exploitation

b) The information gathering phase (reconnaissance) ✔

c) Covering tracks

d) Privilege escalation

Correct answer: b | LO: AS-6.1.1 (K2) | Syllabus §6.1.1

Why: (b) — §6.1.1.

Q7. Derived from syllabus

How can changes in publicly published information affect security testing?

a) They have no effect, because tests target code, not information

b) They make all existing tests invalid immediately

c) Security tests that were valid when created may not provide adequate coverage when published information changes ✔

d) They only affect penetration tests performed by external parties

Correct answer: c | LO: AS-6.1.1 (K2) | Syllabus §6.1.1

Why: (c) — §6.1.1, the impact of human behaviour on **the effectiveness of security testing**.

Q8. Derived from syllabus

Which statement about how attackers operate is correct according to the syllabus?

a) Attackers do not use a security policy or predefined procedures; they decide their strategy from the information they can collect and update their knowledge base for each attack ✔

b) Attackers always follow a fixed methodology, so tests can mirror it exactly

c) Attackers only use information officially published by the organization

d) Attackers never revisit known IP addresses

Correct answer: a | LO: AS-6.1.1 (K2) | Syllabus §6.1.1

Why: (a) — §6.1.1. Employees' social-network posts are also a source, and attackers **visit already known IP addresses**.

Q9. Derived from syllabus

Which of the following is an ACTIVE reconnaissance technique?

a) A Whois lookup

b) Searching the Google Hacking Database

c) Browsing employees' LinkedIn profiles

d) A TCP/UDP scan with Nmap ✔

Correct answer: d | LO: AS-6.1.2 (K3) | Syllabus §6.1.2

Why: (d). Active techniques **touch the system**: pinging, **TCP/UDP scans (Nmap, Zenmap)**, OS detection, service fingerprinting. (a)–(c) are **passive** — no connection to the target.

Q10. Derived from syllabus

A security tester wants to know what an attacker could learn about the company without touching its systems. The company's job adverts list exact product versions, staff email addresses follow firstname.lastname@company, and a public server banner shows an old Apache version.

Which combination best identifies the exposure and a protective measure?

a) Run Nmap against all servers; then disable the firewall to see what changes

b) Use passive sources — search engines and the Google Hacking Database, Shodan for the vulnerable Apache version, social networks and Whois/DNS for names and email structure — then reduce published detail (versions in adverts, banners), patch the exposed server, and include what staff publish in awareness training ✔

c) Ask the attacker community on a forum what they know

d) Wait for an incident and then trace the IP address

Correct answer: b | LO: AS-6.1.2 (K3) | Syllabus §6.1.2

Why: (b). Passive reconnaissance **without actually connecting** uses search engines, the **GHDB**, **Shodan** (e.g. **who runs a vulnerable Apache version**), social networks, **Whois, RIPE, DNS**. The K3 also asks to **apply measures to protect the environment**: reduce footprints, patch what is fingerprinted, and raise awareness.

Q11. Derived from syllabus

Why do attackers try to destroy evidence of a hack, according to the syllabus?

a) Only to avoid prosecution

b) To speed up the attack

c) Because hacking is illegal, and also to lengthen the stay, continue using the system in future, and use the compromised system or botnet to attack others ✔

d) To reduce load on the compromised server

Correct answer: c | LO: AS-6.1.2 (K3) | Syllabus §6.1.2

Why: (c) — §6.1.2. Tools include **NetCat, tunneling, altering log files, hide tools, rootkits and file streaming**.

Q12. Derived from syllabus

Which motivation does the syllabus describe as the most dangerous form, with the highest motivation?

a) Revenge ✔

b) Curiosity

c) Boredom

d) Prestige

Correct answer: a | LO: AS-6.1.3 (K2) | Syllabus §6.1.3

Why: (a) — §6.1.3: **revenge where the latter is considered the most dangerous form (highest motivation)**. Revenge is also **the main insider motivation**.

Q13. Derived from syllabus

Who are "script kiddies"?

a) Professional penetration testers

b) Attackers at the lower end of the spectrum who simply execute the attacks others create ✔

c) Developers who write automation scripts

d) Government-funded attack teams

Correct answer: b | LO: AS-6.1.3 (K2) | Syllabus §6.1.3

Why: (b) — §6.1.3.

Q14. Derived from syllabus

What is hacktivism?

a) Ethical hacking with written authorization

b) Hacking performed by insiders for revenge

c) Hacking out of boredom

d) The attacking of systems on mainly political, but also economic or other demographic grounds ✔

Correct answer: d | LO: AS-6.1.3 (K2) | Syllabus §6.1.3

Why: (d) — §6.1.3.

Q15. Derived from syllabus

What are the three phases of the evidence recovering process in computer forensics?

a) Detect, contain, eradicate

b) Plan, execute, close

c) Acquire and authenticate, analyze, report ✔

d) Identify, protect, recover

Correct answer: c | LO: AS-6.1.4 (K4) | Syllabus §6.1.4

Why: (c) — §6.1.4.

Q16. Derived from syllabus

An IDS alerts on unusual outbound traffic from a database server. What is the correct order of the first actions?

a) Snapshot/copy the system; authenticate the evidence and store a copy safely; analyze; eradicate the cause; recover ✔

b) Reboot the server; patch it; then look at the logs

c) Restore from backup; analyze the backup; report

d) Eradicate the cause; recover; then collect evidence

Correct answer: a | LO: AS-6.1.4 (K4) | Syllabus §6.1.4.1

Why: (a) — the five steps of §6.1.4.1. Restoring or patching first **destroys evidence**; the syllabus says the system is restored **after evidence is collected and stored**.

Q17. Derived from syllabus

A phishing email with a malicious attachment was sent from a web-mail account. The email header shows only the web-mail provider's IP address. Separately, a DDoS against the company used thousands of home PCs.

Which investigative approach best follows the syllabus?

a) For the email, give up because web-mail hides the sender; for the DDoS, trace every home PC owner and prosecute them

b) For the email, look for the X-Originating-IP value and use Whois to contact the ISP; for the DDoS, recognize that botnet investigation is difficult — investigating clients may lead to the server, but access to the server is needed and owners may not know their machines are bots ✔

c) For both, use Netstat on the company firewall only

d) For both, assume the attacker is an insider

Correct answer: b | LO: AS-6.1.4 (K4) | Syllabus §6.1.4.2

Why: (b) — §6.1.4.2: for web-mail **look for the X-Originating-IP value**, then **Whois**; **investigating attacks that used a botnet is difficult** and **owners of these servers may not be aware**.

Q18. Derived from syllabus

After a contractor's access was revoked following a dispute, an internal file share was encrypted and customer pricing appeared on a competitor's site. Logs show the actions came from a still-active service account that the contractor had created during the project.

What are the most likely source and motivation?

a) An external script kiddie motivated by curiosity

b) A hacktivist group motivated by politics

c) A random botnet infection

d) An insider (former contractor using an account they created) motivated by revenge and possibly economic gain from selling information ✔

Correct answer: d | LO: AS-6.1.4 (K4) | Syllabus §6.1.4

Why: (d). Many attacks **come from inside**, **mostly revenge**, with **increasing economic espionage or theft**; the **unexplained account** is one of the syllabus's incident symptoms.

Q19. Derived from syllabus

An unauthorized person follows an employee through a badge-controlled door. What is this called?

a) Shoulder surfing

b) Eavesdropping

c) Tailgating or piggybacking ✔

d) Spear phishing

Correct answer: c | LO: AS-6.2.1 (K2) | Syllabus §6.2

Why: (c) — §6.2.

Q20. Derived from syllabus

What does the syllabus identify as the main defense against social engineering?

a) Education and awareness at all levels in the organization ✔

b) A stronger firewall

c) Encryption of all email

d) A single, well-written social engineering policy

Correct answer: a | LO: AS-6.2.1 (K2) | Syllabus §6.2

Why: (a). There is no single defense; damage can be controlled by **least privilege, separation of duties, rotation of duties**, **but the main defense is education and awareness at all levels**.

Q21. Derived from syllabus

Why is regular security awareness training needed even when previously identified risks never materialized?

a) Because regulators require annual training

b) Because risks that did not become issues are easily forgotten and safeguards withdrawn, increasing opportunities for hacking and social engineering, while the threat model keeps changing ✔

c) Because training replaces technical controls

d) Because only new employees need training

Correct answer: b | LO: AS-6.3.1 (K2) | Syllabus §6.3.1

Why: (b) — §6.3.1.

Q22. Derived from syllabus

A penetration test succeeded by phoning the helpdesk, posing as a travelling manager, and having a password reset without identity verification. The test report is complete and the vulnerability has been fixed.

Which action best uses this outcome to increase security awareness?

a) Keep the result secret permanently and send a generic reminder about passwords

b) Discipline the helpdesk agent publicly

c) Build an awareness case study for helpdesk and general staff answering: how it was done; business consequences; costs to investigate; costs to repair; how it could have been avoided; which changes will be implemented ✔

d) Remove telephone support

Correct answer: c | LO: AS-6.3.2 (K3) | Syllabus §6.3.2

Why: (c) — §6.3.2: training should contain **real case studies — discovered during security testing or in actual incidents** — and answer the **six questions**. (Results stay confidential while unresolved — Chapter 7 — but this one is fixed.)

Most Important Questions From This Chapter

*Ranking rationale: guaranteed **AS-6.1.2 (K3), 6.1.4 (K4), 6.3.2 (K3)** — 7 points; two K2 from 6.1.1/6.1.3/6.2.1/6.3.1.*

Rank	Topic / question focus	LO	Why it matters
1	Attack scenario analysis and forensics — Q4, Q15–Q18	AS-6.1.4	**Guaranteed 3 points.** Follow the timeline.
2	Reconnaissance and protective measures — Q2, Q9–Q11	AS-6.1.2	**Guaranteed 2 points.** Attacker may still be in.
3	Test outcomes → awareness actions — Q5, Q22	AS-6.3.2	**Guaranteed 2 points.** Production first; case studies.
4	Motivations and sources — Q3, Q12–Q14	AS-6.1.3	K2 pool; insider = inside the firewall.
5	Published information risk — Q1, Q6–Q8	AS-6.1.1	K2 pool; process/authority leaks.
6	Social engineering and awareness — Q19–Q21	AS-6.2.1 / 6.3.1	K2 pool.

Section 5 — Exam Tricks

5.1 Frequently tested topics (evidence-based)

LO	K	Pts	Sample #	Format used officially
AS-6.1.1	K2	1	#33	Which published item is a **potential security risk**?
AS-6.1.2	**K3**	2	#34	Shodan hacker, fixed server, no trace → **should you be concerned?**
AS-6.1.3	K2	1	#35	Why is an **inside** attack particularly worrisome?
AS-6.1.4	**K4**	**3**	#36	Long incident story → **next step of investigation**
AS-6.3.2	**K3**	2	#37	MITM found in an upgrade → **what first?**
Chapter 6 total	—	**9**	**#33–#37**	**5.1 points per teaching hour**

> **The arithmetic**
>
> Chapter 6 gives **9 points for 105 minutes** — the same rate as Chapters 2 and 3. Its K4 is a **story question**: long to read, quick to answer once you look for the **first event on the timeline**.

5.2 Common distractors observed

- **Assuming good intent** — "white hat, means no harm".
- **Assuming a patch ends a breach** — the attacker may still have access.
- **Re-running the same tests** — won't reveal an unknown entry point.
- **Curiosity and boredom for insiders** — those fit external attackers; insiders are mostly **revenge**, increasingly **theft/espionage**.
- **Interesting but secondary leads** in a forensic story (dog's name on social media, unhappy colleagues) ahead of **the origin event**.
- **Discouraging the tester** or **telling management after the fact** — testers should attack, and permission comes **before** testing.

5.3 Keyword recognition (map words → answers)

If the stem says...	Think...
"published", "web site", "social network"	**Reconnaissance material** — will be found
"org chart", "approval chain"	**Fraud enabler** (fake invoices)
"Shodan", "Google hacking", "Whois"	**Passive** reconnaissance
"Nmap", "ping", "fingerprint"	**Active** reconnaissance
"no trace of how they got in"	**They can still get in**
"inside the firewall", "authorized user"	**Insider** — external defenses useless
"script kiddie"	**Executes others' attacks**
"political grounds"	**Hacktivism**
"problems started after virus emails"	**Trace the email / IP** first
"X-Originating-IP"	Web-mail sender tracing
"botnet"	**Very hard to trace**
"follow into restricted area"	**Tailgating / piggybacking**

If the stem says...	Think...
"case study", "how did we do it?"	**Awareness training** (six questions)

5.4 Typical traps

- **Many** attacks come from insiders; external hackers are **the minority**.
- **Revenge** appears twice: main insider motive and **most dangerous** external motive.
- **Restore after evidence**, not before.
- **Eradication** (remove the cause) comes **before recovery** (back to normal).
- During an **active** attack, gather information **before locking the attacker out**.
- Any Internet attack **can** be traced — **at a cost** of time, money and effort.

5.5 How to eliminate wrong answers

1. Strike options built on **trust in the attacker**.
2. Strike options that **close the case** without knowing the entry point.
3. In investigations, strike options that skip the **earliest evidence**.
4. In awareness questions, strike options that **punish** rather than **educate**, or that are **generic** rather than case-based.

5.6 Scenario-solving shortcuts

Scenario shape	Shortcut
What is risky to publish?	Information revealing **process, authority or technology**
Attacker disclosed one hole	Assume **persistent access**; find the entry point
Incident with a timeline	**Start at the first event**; then external origin; then insider
Who did it?	Authorized-account traces + grievance → **insider, revenge**
Test found a serious hole in an upgrade	**Production first**, then fix and developer practices
Test outcome to share	**Case study with six questions**

5.7 Common candidate mistakes

- Over-reading the Q36 story — the trick is **when** the problems started.
- Confusing **passive** and **active** reconnaissance — passive never touches the target.
- Forgetting **pop-up screens** and **chat** as computer-based social engineering.

5.8 Mnemonics that carry the whole chapter

Mnemonic	Expands to
"If? No — When."	Published information will be found
A-A-R	Forensics: **A**cquire & authenticate, **A**nalyze, **R**eport
S-C-A-E-R	Steps: **S**napshot, **C**opy (authenticated), **A**nalyze, **E**radicate, **R**ecover
C-P-F-C-B-R	External motives: **C**uriosity, **P**restige, **F**ame, **C**hallenge, **B**oredom, **R**evenge
T-E-S-T (in person)	**T**ailgating, **E**avesdropping, **S**houlder surfing, **T**elephone
How · Biz · Investigate · Repair · Avoid · Change	Six awareness case-study questions

5.9 Chapter 6 mind map

Branch	Leaves
Behaviour	Largest threat, weakest defense · reconnaissance key · published info found · tests lose coverage
Attacker mentality	Passive (search, Shodan, GHDB, social, Whois, RIPE, DNS) · active (ping, Nmap, OS detection, fingerprinting) · hide evidence
Motivation	Insiders (revenge, theft) · externals (curiosity…revenge) · script kiddies → professionals · hacktivism
Forensics	Incident (RFC 2828) · acquire/authenticate, analyze, report · symptoms · five steps · tracing tools · proxies, Tor, botnets
Social engineering	Trust and helpfulness · in person · computer-based · no single defense · education and awareness
Awareness	Changing threat model · forgotten risks · user groups · real case studies · six questions

Section 6 — Revision Notes

6.1 One-page chapter summary

People are the largest threat and the weakest defense. Attacks begin with **reconnaissance**: everything published will be found, by passive means (search engines, Shodan, GHDB, social networks, Whois, RIPE, DNS) or active ones (ping, Nmap scans, OS detection, service fingerprinting). Attackers follow no policy and hide their tracks to stay longer. Many attacks are internal (revenge, theft); external ones are fewer and driven by curiosity through to revenge; attackers range from script kiddies to state-level professionals.

Forensics acquires and authenticates evidence, analyzes it and reports: snapshot, copy, analyze, eradicate, recover; trace via logs, connections, Netstat, Tracert, X-Originating-IP and Whois — hard through proxies, Tor and botnets. **Social engineering** exploits trust in person and by computer; the main defense is **education and awareness**, refreshed as the threat model changes, using **real case studies** answered with six questions.

6.2 Key definitions to memorize

Term	Definition
Reconnaissance	Information gathering / footprinting; the key phase of any attack
Security incident	System event where the security policy is disobeyed or breached
Computer forensics	Finding digital evidence of what happened and who was responsible
Social engineering	Exploiting human behaviour as an attack vector
Script kiddie	Attacker who executes attacks created by others
Hacktivism	Attacks on political (also economic, demographic) grounds

6.3 High-priority concepts (study first)

5. Forensic phases, steps, tracing (**AS-6.1.4**, 3 pts).
6. Passive vs active reconnaissance and protective measures (**AS-6.1.2**, 2 pts).
7. Awareness case studies; production-first on test outcomes (**AS-6.3.2**, 2 pts).
8. Motivations and sources; social engineering techniques (K2 pool).

6.4 Last-minute revision sheet

If you read nothing else

Published info will be found. Org charts → fake-invoice approval chains.

Passive: Google, Shodan, GHDB, LinkedIn/Facebook, Whois, RIPE, DNS. Active: ping, Nmap, Xprobe2, fingerprinting.

Hacker told you one hole and hid the entry → **they can still get in**.

Insider = **inside the firewall, authorized**. Motive: revenge (also theft).

Forensics: acquire & authenticate → analyze → report. Snapshot → copy → analyze → eradicate → recover.

Incident after virus emails → **trace the email/IP first**.

Social engineering: tailgating, eavesdropping, shoulder surfing, phone; malware mail, chat, pop-ups, spam, (spear) phishing. Main defense: **awareness**.

Awareness: case studies — how, consequences, investigate cost, repair cost, avoidance, changes.

6.5 Memorization checklist

✓	I can...
☐	explain why reconnaissance is the key phase and how published info affects testing

✓	I can…
☐	list five passive and four active reconnaissance tools/methods
☐	contrast insider and external motivations and name the most dangerous
☐	give the three forensic phases, six symptoms and five steps
☐	explain how to trace email and why botnets are hard
☐	list nine social engineering techniques and the main defense
☐	give the six awareness case-study questions

6.6 Exam-day quick review

- **Trust no attacker; assume persistence.**
- **First event on the timeline = first place to investigate.**
- **Insiders are already past the firewall.**